

Actividad 3



Karol Paulina Rentería Carreño

Seguridad de Software

Tutor: Luis Antonio Sarruf Durango

Universidad de Cartagena

Ingeniería de Software

Cereté, Córdoba

2026

Contenido

1. Introducción	3
2. Alcance	5
3. Desarrollo técnico.....	6
4. Desarrollo Conceptual	8
5. Desarrollo Practico	11
6. Conclusiones	30
7. Referencias.....	32

1.Introducción

En el contexto actual de la seguridad informática, la evaluación de vulnerabilidades en sistemas y aplicaciones web constituye una práctica fundamental para garantizar la protección de la información. El incremento de amenazas cibernéticas ha generado la necesidad de implementar metodologías que permitan identificar fallas de seguridad y analizar los posibles riesgos a los que se enfrentan los sistemas.

En este sentido, las pruebas de penetración y auditorías de seguridad permiten simular ataques controlados con el objetivo de detectar debilidades antes de que puedan ser explotadas por actores maliciosos. Estas prácticas no solo permiten identificar vulnerabilidades, sino también comprender el impacto que estas pueden tener sobre la confidencialidad, integridad y disponibilidad de la información.

Para el desarrollo de este tipo de actividades, los entornos virtualizados representan una herramienta esencial, ya que permiten crear escenarios controlados donde es posible ejecutar pruebas de seguridad sin afectar sistemas reales. Mediante el uso de plataformas de virtualización, se pueden configurar múltiples máquinas con roles específicos dentro de un laboratorio de pruebas.

En el presente trabajo se implementó un entorno virtual compuesto por dos máquinas: Kali Linux, utilizada como sistema de auditoría, y Metasploitable 2, configurada como máquina vulnerable. A partir de este entorno se realizaron diferentes pruebas de seguridad, incluyendo verificación de conectividad, escaneo de servicios mediante Nmap, pruebas de Cross-Site Request Forgery (CSRF), validación de seguridad en la capa de transporte (SSL/TLS) y análisis de vulnerabilidades basadas en el estándar OWASP Top Ten.

De esta manera, la actividad permitió aplicar de forma práctica los conocimientos adquiridos en la unidad 3, fortaleciendo las competencias en análisis de vulnerabilidades y auditoría de seguridad en entornos controlados.

2.Alcance

El presente trabajo tiene como alcance la implementación de un entorno virtualizado orientado a la auditoría de seguridad en sistemas informáticos, con el propósito de identificar vulnerabilidades y evaluar posibles riesgos en aplicaciones y servicios expuestos. Para el desarrollo de la actividad, se utilizó una infraestructura de laboratorio compuesta por dos máquinas virtuales: Kali Linux, empleada como herramienta de análisis y ejecución de pruebas de seguridad, y Metasploitable 2, configurada como sistema vulnerable para la simulación de ataques.

Dentro de este entorno controlado, se llevaron a cabo diversas pruebas orientadas a la identificación de vulnerabilidades, incluyendo la verificación de conectividad mediante herramientas de red, el reconocimiento de servicios activos utilizando Nmap y la evaluación de aplicaciones web vulnerables. Asimismo, se realizaron pruebas específicas como la ejecución de ataques de tipo Cross-Site Request Forgery (CSRF), la validación de la seguridad en la capa de transporte mediante el análisis de SSL/TLS y la identificación de vulnerabilidades conforme al estándar OWASP Top Ten.

Es importante resaltar que todas las pruebas fueron realizadas en un entorno aislado y controlado, con fines estrictamente académicos, evitando cualquier impacto sobre sistemas reales. De esta manera, el alcance de la actividad se limita a la simulación de escenarios de auditoría de seguridad, con el objetivo de fortalecer el aprendizaje práctico en el área de la ciberseguridad.

3.Desarrollo técnico

Para la realización de la presente actividad se implementó un entorno de laboratorio basado en tecnologías de virtualización, con el objetivo de simular un escenario controlado de auditoría de seguridad en sistemas informáticos. Este tipo de entornos permite ejecutar pruebas de análisis y detección de vulnerabilidades sin comprometer infraestructuras reales. En este contexto, se utilizó la herramienta de virtualización VirtualBox, la cual permitió la creación y ejecución de múltiples máquinas virtuales dentro de un mismo equipo físico. Gracias a esta tecnología, fue posible configurar un entorno aislado donde se desarrollaron las pruebas de seguridad correspondientes a la actividad.

La primera máquina virtual implementada fue Kali Linux, una distribución especializada en seguridad informática que cuenta con herramientas para auditoría, análisis de vulnerabilidades y pruebas de penetración. En este laboratorio, Kali Linux fue utilizada como la máquina atacante, desde la cual se realizaron las pruebas de conectividad, escaneo de red y evaluación de vulnerabilidades. Por otra parte, se utilizó Metasploitable 2 como máquina víctima. Este sistema fue diseñado intencionalmente con múltiples vulnerabilidades, lo que lo convierte en una herramienta ideal para la práctica de pruebas de seguridad en entornos académicos. En esta máquina se ejecutaron servicios vulnerables que posteriormente fueron analizados desde Kali Linux.

Para permitir la comunicación entre ambas máquinas virtuales, se configuró una red de tipo Host-Only en VirtualBox, lo que permitió que Kali Linux y Metasploitable 2 compartieran un mismo segmento de red privada. A través de esta configuración, ambas máquinas obtuvieron direcciones IP dentro del rango 192.168.56.0/24, lo que facilitó la comunicación directa entre ellas. Una vez establecida la red, se verificó la conectividad mediante el uso del comando ping desde la máquina Kali Linux hacia la máquina Metasploitable, confirmando la correcta comunicación entre

los sistemas. Posteriormente, se utilizó la herramienta Nmap para realizar el reconocimiento de puertos y servicios activos en la máquina víctima, identificando múltiples servicios expuestos como FTP, SSH, Telnet, HTTP y bases de datos, los cuales representan posibles puntos de vulnerabilidad.

Finalmente, el entorno configurado permitió llevar a cabo diferentes pruebas de seguridad, incluyendo ataques de tipo CSRF, validación de seguridad en la capa de transporte (SSL/TLS) y análisis de vulnerabilidades según el estándar OWASP Top Ten. Este entorno resultó fundamental para el desarrollo práctico de la actividad, permitiendo aplicar los conocimientos adquiridos en un escenario realista y controlado.

4.Desarrollo Conceptual

4.1 Seguridad de software

La seguridad de software constituye un conjunto de prácticas, metodologías y herramientas orientadas a proteger aplicaciones y sistemas frente a amenazas que puedan comprometer la información. Su objetivo principal es garantizar la confidencialidad, integridad y disponibilidad de los datos, principios fundamentales dentro de la ciberseguridad. En este sentido, la seguridad de software no solo implica la detección de vulnerabilidades, sino también la implementación de mecanismos preventivos que reduzcan el riesgo de explotación. Según Menejías García et al. (2021), la evaluación de seguridad en productos de software permite identificar debilidades estructurales y establecer controles que fortalezcan la resistencia ante ataques informáticos.

4.2 Virtualización en entornos de seguridad

La virtualización es una tecnología que permite la creación de múltiples entornos de ejecución dentro de un mismo equipo físico, mediante la abstracción de los recursos de hardware. Esta técnica es ampliamente utilizada en el ámbito de la seguridad informática debido a su capacidad para generar entornos aislados y controlados. En dichos entornos, es posible simular escenarios reales de ataque y defensa sin comprometer sistemas productivos. De acuerdo con Barchino Plata et al. (2020), la virtualización facilita la experimentación en redes y sistemas, permitiendo a los usuarios realizar pruebas complejas de configuración y seguridad de manera segura y eficiente.

4.3 Reconocimiento y análisis de servicios con Nmap

El reconocimiento de servicios constituye una de las primeras fases dentro de una auditoría de seguridad, ya que permite identificar los puntos de acceso disponibles en un sistema. Esta etapa incluye la detección de puertos abiertos, servicios activos y versiones de software, lo cual resulta esencial para identificar posibles vulnerabilidades. La herramienta Nmap es una de las más utilizadas en este proceso, debido a su capacidad para realizar escaneos avanzados de red y proporcionar información detallada sobre la infraestructura del sistema objetivo. Según Lyon (2009), Nmap permite no solo identificar servicios, sino también detectar configuraciones inseguras y ejecutar scripts que revelan vulnerabilidades específicas, lo cual la convierte en una herramienta clave en pruebas de penetración.

4.4 Cross-Site Request Forgery (CSRF)

El Cross-Site Request Forgery (CSRF) es una vulnerabilidad que se presenta cuando una aplicación web no valida adecuadamente las solicitudes realizadas por un usuario autenticado. Este tipo de ataque permite que un atacante induzca a un usuario legítimo a ejecutar acciones no autorizadas sin su consentimiento, aprovechando la sesión activa del usuario en la aplicación. Según OWASP (2023), el CSRF ocurre cuando las aplicaciones no implementan mecanismos de protección como tokens de validación o verificación de origen, lo que permite la ejecución de solicitudes maliciosas. Esta vulnerabilidad puede tener consecuencias graves, como la modificación de datos, cambio de contraseñas o ejecución de transacciones no autorizadas.

4.5 Seguridad en la capa de transporte (SSL/TLS)

La seguridad en la capa de transporte se basa en el uso de protocolos criptográficos como SSL (Secure Sockets Layer) y TLS (Transport Layer Security), los cuales permiten cifrar la comunicación entre un cliente y un servidor. Este cifrado garantiza que la información transmitida no pueda ser interceptada o modificada por terceros. Sin embargo, el uso de versiones obsoletas o la ausencia de estos protocolos representa un riesgo significativo para la seguridad de los sistemas. De acuerdo con OWASP (2023), las fallas criptográficas se presentan cuando los sistemas no implementan correctamente mecanismos de cifrado, lo que puede dar lugar a ataques de tipo Man-in-the-Middle (MITM), en los cuales un atacante intercepta la comunicación entre las partes.

4.6 OWASP Top Ten y gestión de vulnerabilidades

El OWASP Top Ten es un estándar reconocido a nivel mundial que identifica las principales vulnerabilidades presentes en aplicaciones web. Este listado es desarrollado por la organización OWASP y se actualiza periódicamente con base en datos reales sobre incidentes de seguridad. Entre las vulnerabilidades más relevantes se encuentran fallas en el control de acceso, errores criptográficos, configuraciones incorrectas de seguridad y vulnerabilidades como CSRF. Según OWASP (2023), este estándar sirve como guía para desarrolladores, auditores y organizaciones, permitiendo priorizar riesgos y aplicar medidas de mitigación adecuadas. La adopción del OWASP Top Ten en procesos de auditoría contribuye significativamente a mejorar la seguridad de las aplicaciones y reducir la exposición a amenazas.

5.Desarrollo Practico

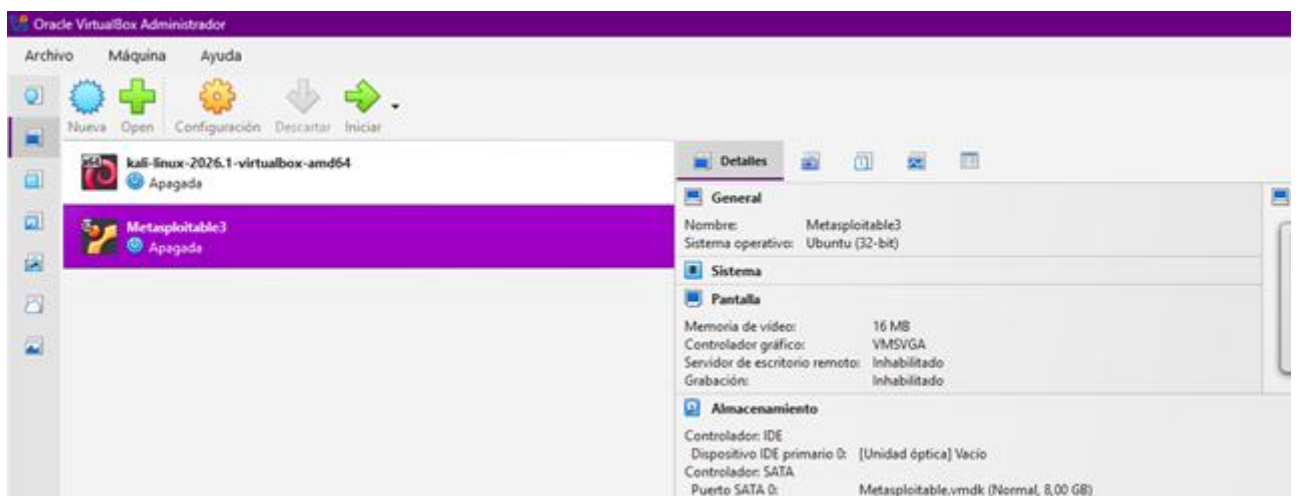
5.1 Despliegue del entorno virtualizado

Para el desarrollo de la actividad se implementó un entorno virtualizado utilizando la herramienta VirtualBox, con el objetivo de simular un escenario controlado de auditoría de seguridad. En este entorno se configuraron dos máquinas virtuales: Kali Linux, utilizada como máquina atacante, y Metasploitable 2, empleada como máquina víctima con múltiples vulnerabilidades predefinidas.

Inicialmente, se realizó la importación de la máquina Kali Linux mediante un archivo preconfigurado, lo cual permitió disponer de un sistema listo para ejecutar herramientas de seguridad. Posteriormente, se creó la máquina virtual Metasploitable 2 a partir de un disco virtual, configurando sus parámetros básicos como memoria RAM, tipo de sistema operativo y almacenamiento.

Figura 1.

Máquinas virtuales configuradas en VirtualBox.



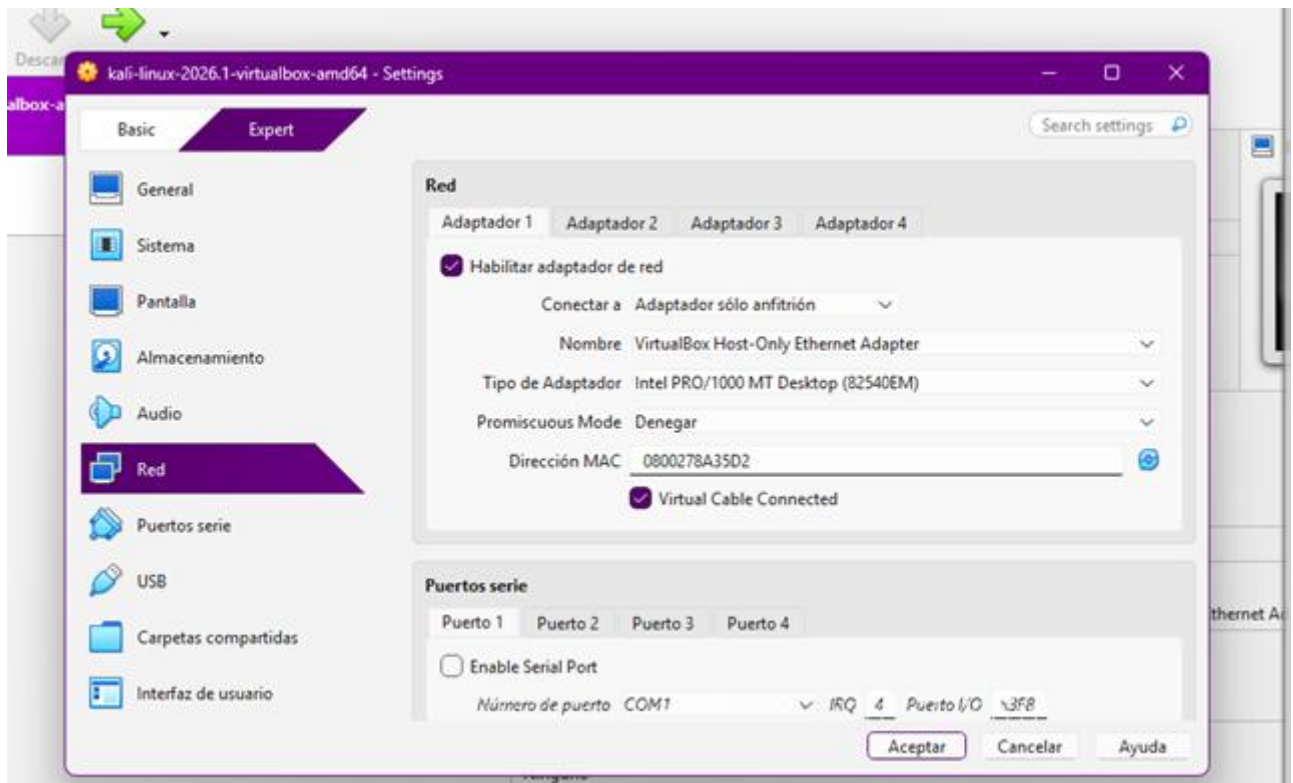
Nota. Se observa la creación e importación de las máquinas Kali Linux y Metasploitable dentro del entorno de virtualización.

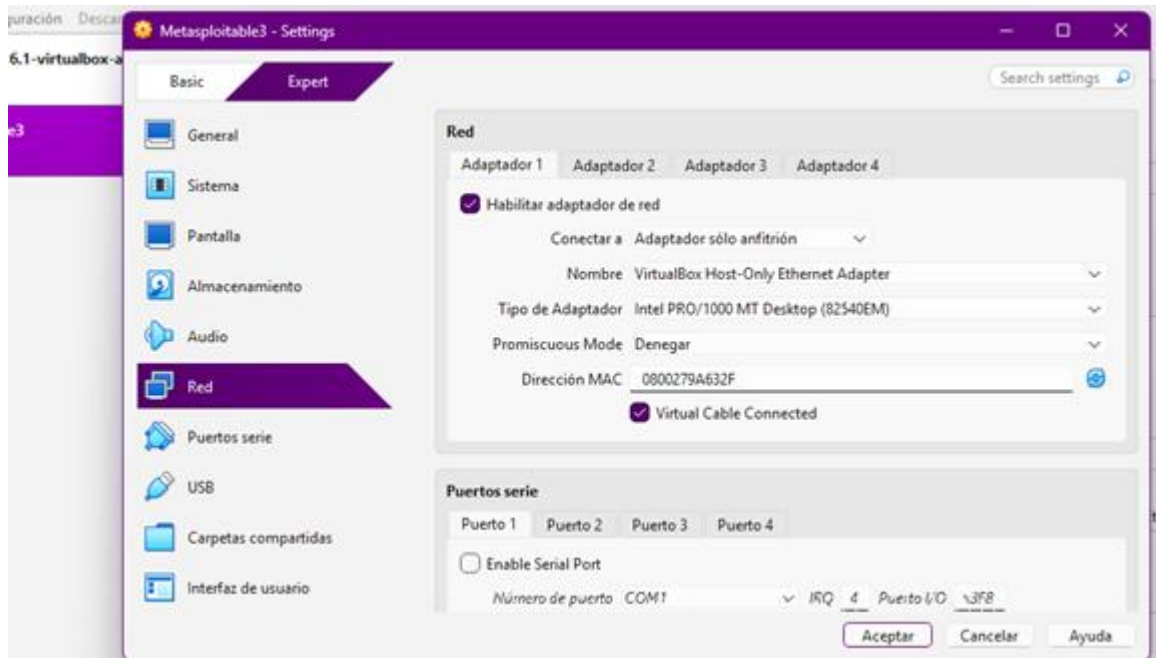
5.2 Configuración de red en el entorno virtual

Con el fin de permitir la comunicación entre las máquinas virtuales, se configuró una red de tipo Host-Only en VirtualBox. Esta configuración permite la interacción entre las máquinas dentro de un entorno aislado, sin acceso a redes externas. En cada una de las máquinas se habilitó el Adaptador 1 y se seleccionó la opción correspondiente a red Host-Only, asegurando que ambas pertenecieran al mismo segmento de red virtual. Esta configuración permitió que las máquinas obtuvieran direcciones IP dentro del rango 192.168.56.0/24.

Figura 2.

Configuración del adaptador de red en modo Host-Only.





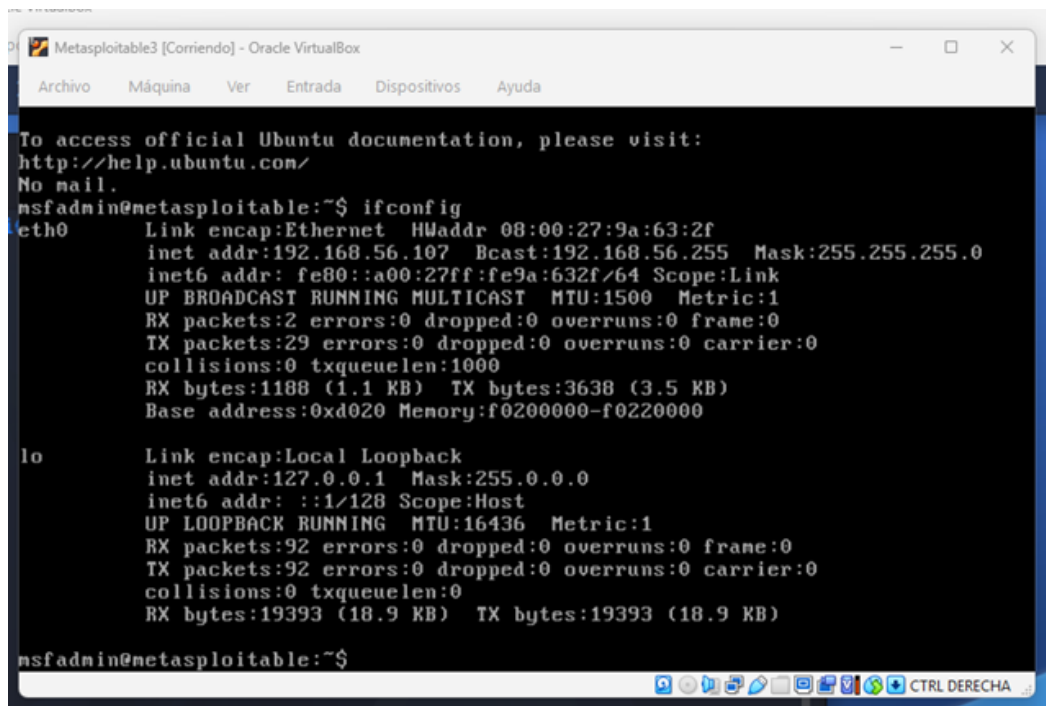
Nota. Configuración realizada en ambas máquinas virtuales para permitir la comunicación dentro del laboratorio.

5.3 Verificación de direccionamiento IP

Una vez configurada la red, se procedió a verificar las direcciones IP asignadas a cada máquina. En la máquina Metasploitable se utilizó el comando `ifconfig`, mientras que en Kali Linux se empleó el comando `ip a`. Como resultado, se identificaron direcciones IP válidas dentro del mismo segmento de red, lo cual es un requisito fundamental para la comunicación entre sistemas.

Figura 3.

Dirección IP de la máquina Metasploitable.



```
Metasploitable3 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

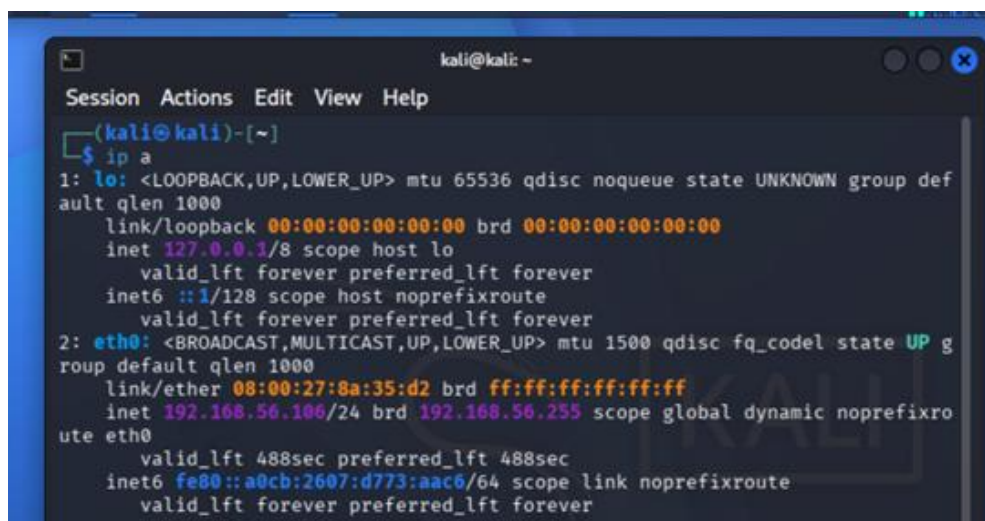
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:9a:63:2f
          inet addr:192.168.56.107  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe9a:632f/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:92 errors:0 dropped:0 overruns:0 frame:0
          TX packets:92 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19393 (18.9 KB)  TX bytes:19393 (18.9 KB)

msfadmin@metasploitable:~$
```

Figura 4.

Dirección IP de la máquina Kali Linux.



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.106/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 488sec preferred_lft 488sec
    inet6 fe80::a0cb:2607:d773:aac6/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Nota. Ambas máquinas presentan direcciones dentro del mismo rango de red, lo que permite la conectividad.

5.4 Escaneo de puertos y servicios con Nmap

Una vez verificada la conectividad entre las máquinas virtuales, se procedió a realizar el reconocimiento de servicios en la máquina víctima (Metasploitable) utilizando la herramienta Nmap desde Kali Linux. Este proceso corresponde a la fase de reconocimiento activo, en la cual se identifican puertos abiertos, servicios en ejecución y versiones de software instaladas en el sistema objetivo. Para ello, se ejecutó el siguiente comando: `nmap -sV -A 192.168.56.107`

Donde:

- `-sV` permite identificar las versiones de los servicios activos
- `-A` habilita detección avanzada, incluyendo sistema operativo, scripts y traceroute

A partir del escaneo realizado, se identificaron múltiples puertos abiertos y servicios activos, entre los cuales se destacan:

- Puerto 21 (FTP): Servicio vsftpd 2.3.4 con acceso anónimo habilitado, lo que representa una vulnerabilidad crítica de acceso no autorizado.
- Puerto 22 (SSH): Servicio OpenSSH utilizado para acceso remoto seguro, aunque con versiones antiguas que pueden presentar vulnerabilidades.
- Puerto 23 (Telnet): Servicio de acceso remoto sin cifrado, considerado inseguro debido a la transmisión de credenciales en texto plano.
- Puerto 25 (SMTP): Servicio de correo electrónico que presenta soporte para protocolos inseguros como SSLv2.
- Puerto 80 (HTTP): Servidor web Apache 2.2.8, el cual permite el acceso a aplicaciones web vulnerables como DVWA.

- Puerto 139 y 445 (Samba): Servicios de compartición de archivos que pueden ser explotados en sistemas mal configurados.
- Puerto 3306 (MySQL): Servicio de base de datos activo, potencialmente vulnerable a ataques de inyección SQL.
- Puerto 5432 (PostgreSQL): Otro sistema gestor de base de datos expuesto.
- Puerto 5900 (VNC): Servicio de escritorio remoto, el cual puede permitir acceso gráfico al sistema si no está protegido adecuadamente.

Adicionalmente, se identificaron otros servicios como Bind Shell (puerto 1524), IRC (6667) y Tomcat (8180), los cuales incrementan significativamente la superficie de ataque del sistema.

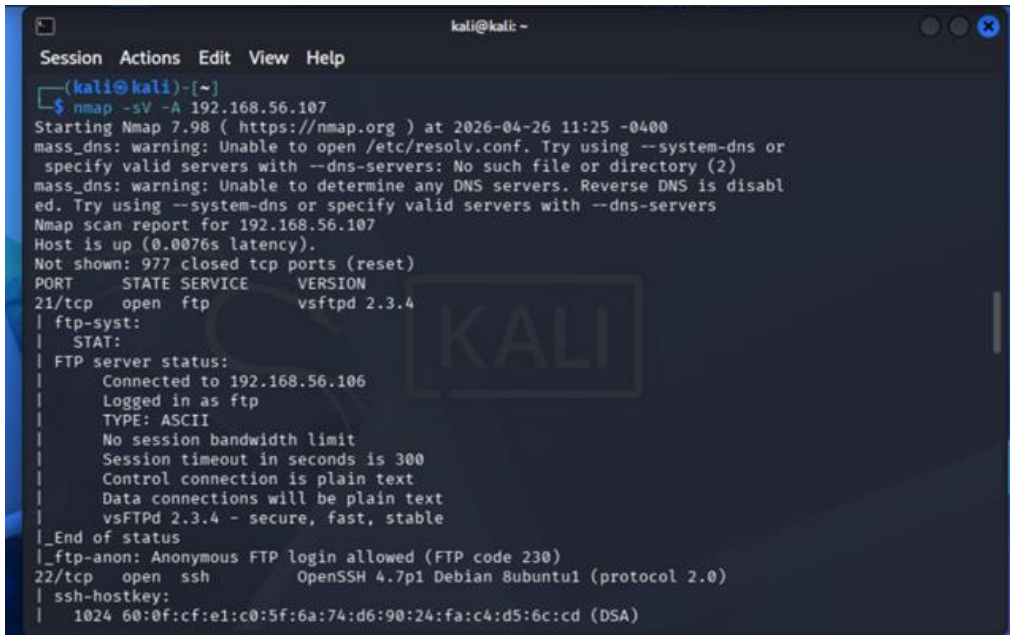
Los resultados obtenidos evidencian que la máquina Metasploitable presenta una gran cantidad de servicios activos y expuestos, muchos de ellos con configuraciones inseguras o versiones desactualizadas. Entre los hallazgos más relevantes se encuentran:

- Acceso anónimo permitido en FTP
- Uso de protocolos inseguros como Telnet
- Implementación de cifrado obsoleto (SSLv2)
- Presencia de servicios innecesarios abiertos

Esta situación representa un alto riesgo de seguridad, ya que cada servicio activo puede ser utilizado como punto de entrada por un atacante para comprometer el sistema.

Figura 6.

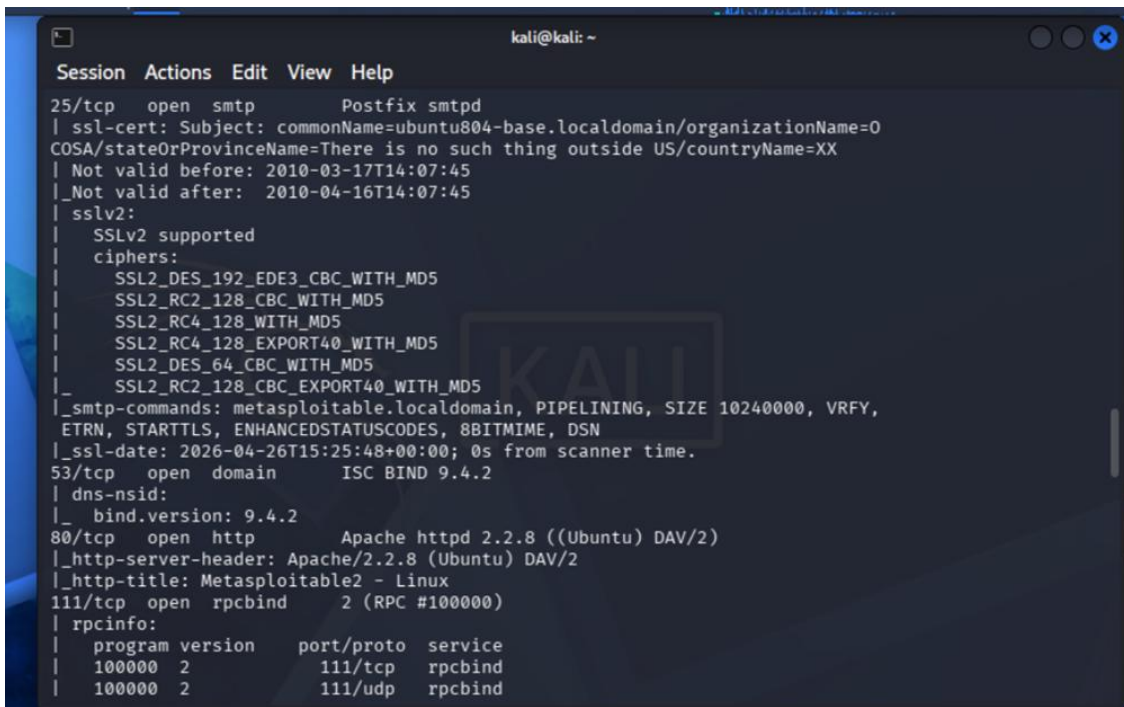
Resultados del escaneo de puertos y servicios con Nmap.



```
kali@kali: ~  
Session Actions Edit View Help  
$ nmap -sV -A 192.168.56.107  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 11:25 -0400  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or  
specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl  
ed. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.107  
Host is up (0.0076s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp           vsftpd 2.3.4  
| ftp-syst:  
| STAT:  
| FTP server status:  
|   Connected to 192.168.56.106  
|   Logged in as ftp  
|   TYPE: ASCII  
|   No session bandwidth limit  
|   Session timeout in seconds is 300  
|   Control connection is plain text  
|   Data connections will be plain text  
|   vsFTPd 2.3.4 - secure, fast, stable  
|_ End of status  
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
| ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
```

Figura 7.

Detalle de servicios activos y versiones detectadas.



```
kali@kali: ~  
Session Actions Edit View Help  
25/tcp    open  smtp          Postfix smtpd  
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=0  
COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
| Not valid before: 2010-03-17T14:07:45  
|_ Not valid after: 2010-04-16T14:07:45  
|_ sslv2:  
|   SSLv2 supported  
|   ciphers:  
|     SSL2_DES_192_EDE3_CBC_WITH_MD5  
|     SSL2_RC2_128_CBC_WITH_MD5  
|     SSL2_RC4_128_WITH_MD5  
|     SSL2_RC4_128_EXPORT40_WITH_MD5  
|     SSL2_DES_64_CBC_WITH_MD5  
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_ smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,  
ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
|_ ssl-date: 2026-04-26T15:25:48+00:00; 0s from scanner time.  
53/tcp    open  domain        ISC BIND 9.4.2  
| dns-nsid:  
|_ bind.version: 9.4.2  
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2  
|_ http-title: Metasploitable2 - Linux  
111/tcp   open  rpcbind       2 (RPC #100000)  
| rpcinfo:  
|   program version    port/proto  service  
|   100000  2          111/tcp    rpcbind  
|   100000  2          111/udp    rpcbind
```

```
kali@kali: ~  
Session Actions Edit View Help  
| 100000 2 111/udp rpcbind  
| 100003 2,3,4 2049/tcp nfs  
| 100003 2,3,4 2049/udp nfs  
| 100005 1,2,3 44018/udp mountd  
| 100005 1,2,3 44571/tcp mountd  
| 100021 1,3,4 56530/tcp nlockmgr  
| 100021 1,3,4 56799/udp nlockmgr  
| 100024 1 39784/udp status  
| 100024 1 58641/tcp status  
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp open exec netkit-rsh rshcd  
513/tcp open login  
514/tcp open shell Netkit rshd  
1099/tcp open java-rmi GNU Classpath grmiregistry  
1524/tcp open bindshell Metasploitable root shell  
2049/tcp open nfs 2-4 (RPC #100003)  
2121/tcp open ftp ProFTPD 1.3.1  
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5  
| mysql-info:  
| Protocol: 10  
| Version: 5.0.51a-3ubuntu5  
| Thread ID: 8  
| Capabilities flags: 43564  
| Some Capabilities: SwitchToSSLAfterHandshake, ConnectWithDatabase, LongCo  
lumnFlag, SupportsTransactions, Support41Auth, Speaks41ProtocolNew, SupportsC  
ompression  
| Status: Autocommit
```

Figura 8.

Información adicional del sistema y scripts ejecutados por Nmap.

```
kali@kali: ~  
Session Actions Edit View Help  
|_ Salt: %C_5,{KCOA98N^m-5`gb  
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7  
|_ ssl-date: 2026-04-26T15:25:48+00:00; 0s from scanner time.  
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=0  
COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_ Not valid before: 2010-03-17T14:07:45  
|_ Not valid after: 2010-04-16T14:07:45  
5900/tcp open vnc VNC (protocol 3.3)  
|_ vnc-info:  
| Protocol version: 3.3  
| Security types:  
|_ VNC Authentication (2)  
6000/tcp open X11 (access denied)  
6667/tcp open irc UnrealIRCd  
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)  
|_ ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1  
|_ http-server-header: Apache-Coyote/1.1  
|_ http-favicon: Apache Tomcat  
|_ http-title: Apache Tomcat/5.5  
MAC Address: 08:00:27:9A:63:2F (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs  
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
kali@kali: ~  
Session Actions Edit View Help  
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Host script results:  
| smb-os-discovery:  
|   OS: Unix (Samba 3.0.20-Debian)  
|   Computer name: metasploitable  
|   NetBIOS computer name:  
|   Domain name: localdomain  
|   FQDN: metasploitable.localdomain  
|   System time: 2026-04-26T11:25:40-04:00  
|_ smb-security-mode:  
|   account_used: guest  
|   authentication_level: user  
|   challenge_response: supported  
|_ message_signing: disabled (dangerous, but default)  
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s  
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:  
|   <unknown> (unknown)  
|_ smb2-time: Protocol negotiation failed (SMB2)  
  
TRACEROUTE  
HOP RTT    ADDRESS  
1   7.62 ms 192.168.56.107  
  
OS and Service detection performed. Please report any incorrect results at ht  
tps://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 23.90 seconds
```

Nota.

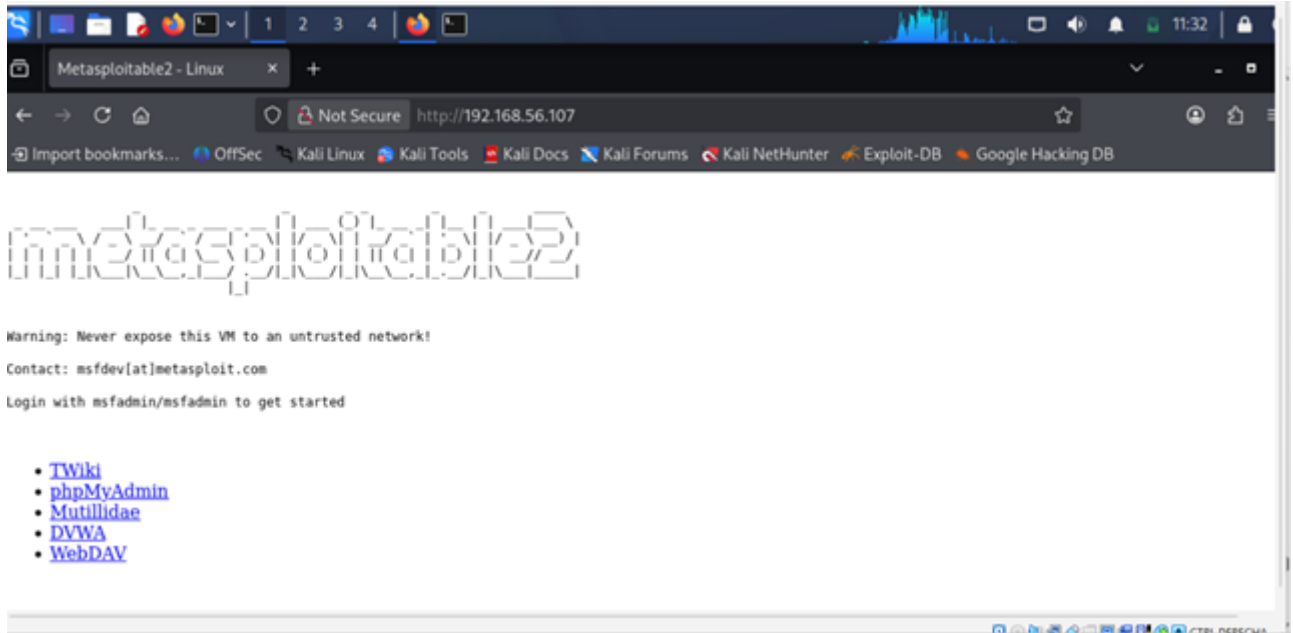
Se identifican múltiples servicios activos y vulnerabilidades potenciales en la máquina Metasploitable, evidenciando una amplia superficie de ataque que puede ser explotada mediante técnicas de penetración.

5.5 Acceso a la aplicación web vulnerable

Durante el escaneo de puertos se identificó que el puerto 80 (HTTP) se encontraba activo en la máquina Metasploitable. Esto permitió acceder al servidor web mediante un navegador desde Kali Linux, ingresando la dirección IP de la máquina víctima. Como resultado, se visualizó una interfaz con diversas aplicaciones vulnerables, entre las cuales se seleccionó DVWA (Damn Vulnerable Web Application) para la ejecución de pruebas de seguridad.

Figura 7.

Acceso al servidor web vulnerable desde el navegador.



5.6 Ejecución de ataque CSRF

Dentro de la aplicación DVWA, se accedió al módulo correspondiente a Cross-Site Request Forgery (CSRF). Previamente, se configuró el nivel de seguridad de la aplicación en “Low” con el fin de facilitar la ejecución de pruebas. Posteriormente, se procedió a realizar un cambio de contraseña dentro de la aplicación sin la implementación de mecanismos de validación, lo que permitió evidenciar la vulnerabilidad CSRF. Esta situación demuestra que la aplicación no cuenta con medidas de protección como tokens de seguridad, permitiendo la ejecución de acciones sin la debida autenticación.

Figura 8.

Inicio de sesión en DVWA.



Figura 9.

Configuración de seguridad en nivel bajo.

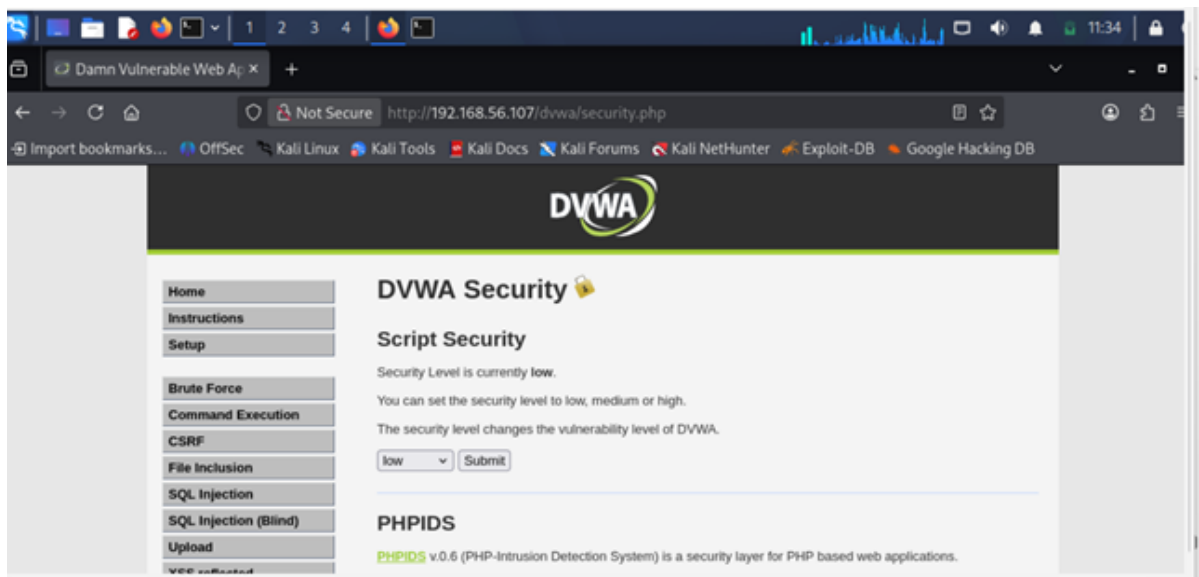
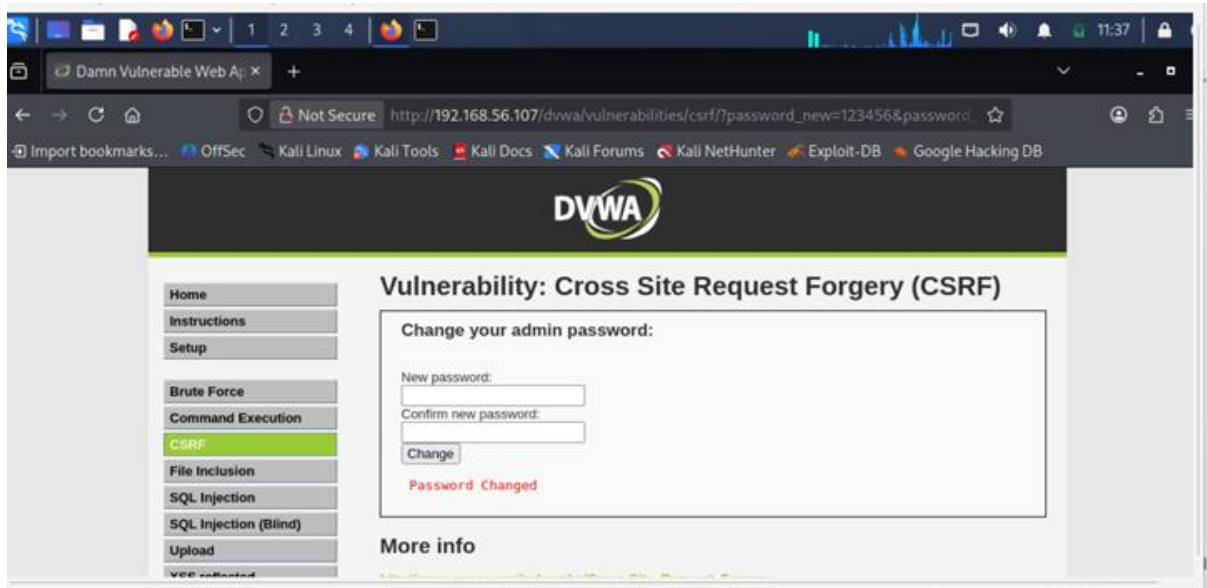


Figura 10.

Ejecución de ataque CSRF.



Nota. Se evidencia la modificación de datos sin mecanismos de validación adecuados.

5.7 Validación de seguridad en la capa de transporte (SSL/TLS)

Con el fin de evaluar la seguridad en la capa de transporte del sistema, se realizó una prueba de acceso al servidor web de la máquina Metasploitable utilizando el protocolo HTTPS, el cual está diseñado para garantizar la confidencialidad e integridad de la información mediante el uso de cifrado criptográfico.

Para ello, desde la máquina Kali Linux se intentó establecer una conexión segura a través del navegador web ingresando la dirección correspondiente a la máquina víctima utilizando el esquema `https://`. Sin embargo, como resultado de esta prueba, no fue posible establecer una conexión segura con el servidor, lo que indica que el sistema no cuenta con una implementación adecuada de SSL/TLS o que el servicio HTTPS no se encuentra habilitado.

Adicionalmente, al acceder al servidor mediante el protocolo HTTP (<http://>), el navegador indicó explícitamente que la conexión no es segura, mostrando advertencias relacionadas con la falta de cifrado. Este comportamiento evidencia que la información transmitida entre el cliente y el servidor se realiza en texto plano, sin ningún tipo de protección criptográfica, lo que la hace susceptible a ser interceptada por terceros.

Desde una perspectiva de seguridad, esta situación representa una vulnerabilidad crítica, ya que permite la ejecución de ataques de tipo Man-in-the-Middle (MITM), en los cuales un atacante puede interceptar, modificar o incluso redirigir la comunicación entre las partes sin que estas lo detecten. Asimismo, la ausencia de cifrado facilita la captura de datos sensibles como credenciales de acceso, información personal o datos transmitidos a través de formularios web.

Es importante destacar que, de acuerdo con los resultados obtenidos previamente mediante la herramienta Nmap, el sistema presenta soporte para protocolos criptográficos obsoletos como SSLv2, lo cual agrava aún más la situación de seguridad. El uso de este tipo de protocolos está desaconsejado debido a que contienen vulnerabilidades conocidas que pueden ser explotadas fácilmente por atacantes. En este sentido, la falta de implementación de HTTPS y el uso de mecanismos criptográficos inseguros se clasifican dentro de la categoría de fallas criptográficas (Cryptographic Failures) según el estándar OWASP Top Ten, ya que comprometen directamente la confidencialidad de la información.

Figura 11.

Conexión no segura en el navegador mediante HTTP.

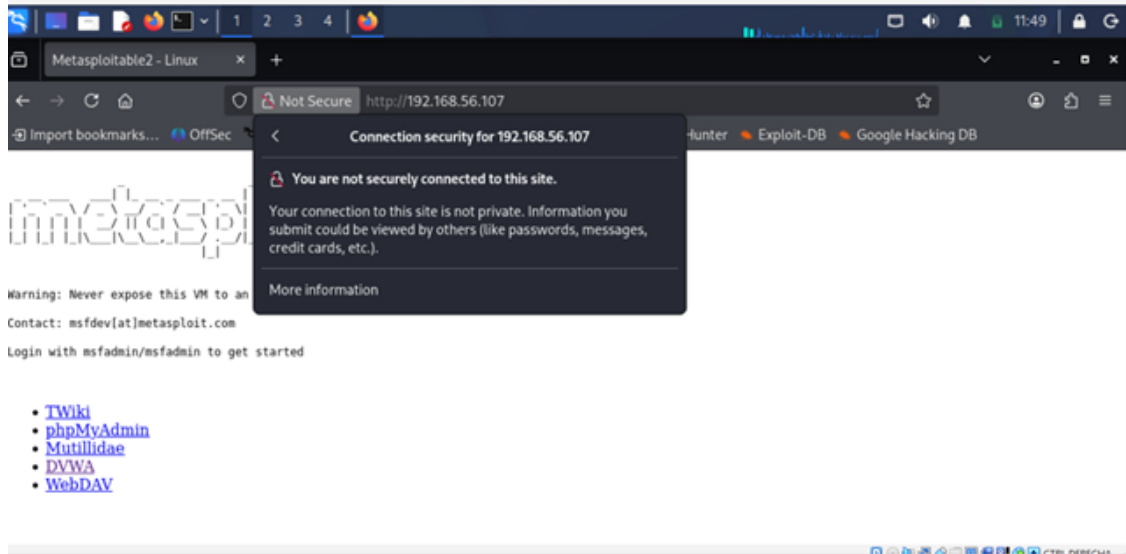
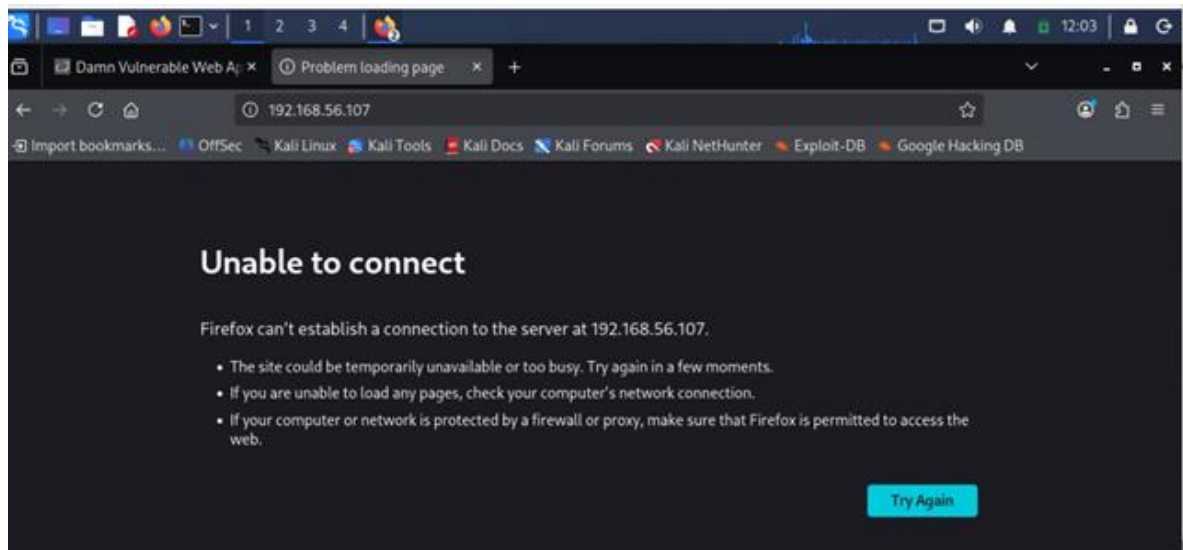


Figura 12.

Intento fallido de conexión mediante HTTPS.



Nota.

Se evidencia la ausencia de mecanismos de cifrado en la comunicación entre cliente y servidor, así como la falta de implementación de protocolos seguros de transporte, lo que representa un riesgo significativo para la seguridad de la información.

5.8 Identificación de vulnerabilidades según OWASP Top Ten

Finalmente, se llevó a cabo el análisis de las vulnerabilidades presentes en la máquina Metasploitable, tomando como referencia el estándar OWASP Top Ten, el cual reúne las principales categorías de riesgos de seguridad en aplicaciones web a nivel mundial. Este análisis permitió clasificar las debilidades identificadas durante las pruebas prácticas dentro de un marco reconocido, facilitando su comprensión y evaluación.

A partir de los resultados obtenidos mediante el escaneo con Nmap, la exploración de servicios y la ejecución de pruebas en la aplicación DVWA, se identificaron diversas vulnerabilidades críticas, las cuales se describen a continuación:

5.8.1 Broken Access Control (Fallas en el control de acceso)

Durante el análisis se evidenció que el servicio FTP (puerto 21) permite el acceso anónimo sin requerir autenticación, tal como se observó en los resultados del escaneo con Nmap. Esta configuración permite que cualquier usuario pueda acceder al sistema sin credenciales, lo que constituye una falla grave en el control de acceso.

Este tipo de vulnerabilidad puede ser explotado por atacantes para visualizar, modificar o eliminar archivos, comprometiendo la integridad y confidencialidad de la información.

5.8.2 Cryptographic Failures (Fallas criptográficas)

Se identificó la ausencia de implementación adecuada de protocolos seguros de comunicación, ya que el sistema no permite establecer conexiones mediante HTTPS.

Adicionalmente, se detectó el uso de protocolos obsoletos como SSLv2 en algunos servicios. Estas deficiencias implican que la información transmitida entre cliente y servidor no se encuentra cifrada o utiliza mecanismos inseguros, lo que facilita la ejecución de ataques de interceptación, como los ataques Man-in-the-Middle (MITM).

5.8.3 Security Misconfiguration (Mala configuración de seguridad)

El sistema presenta múltiples servicios activos innecesarios o mal configurados, como Telnet (puerto 23), el cual transmite información en texto plano sin cifrado. Asimismo, se detectaron servicios como Samba, VNC y bases de datos expuestas sin restricciones adecuadas. La presencia de estos servicios incrementa la superficie de ataque del sistema y facilita la explotación de vulnerabilidades por parte de un atacante.

5.8.4 Cross-Site Request Forgery (CSRF)

Mediante el uso de la aplicación DVWA, se logró ejecutar un ataque de tipo CSRF, evidenciando que la aplicación permite realizar cambios en la información del usuario sin implementar mecanismos de validación, como tokens de seguridad. Esta vulnerabilidad permite que un atacante ejecute acciones en nombre de un usuario autenticado, comprometiendo la integridad de la información y la seguridad de la aplicación.

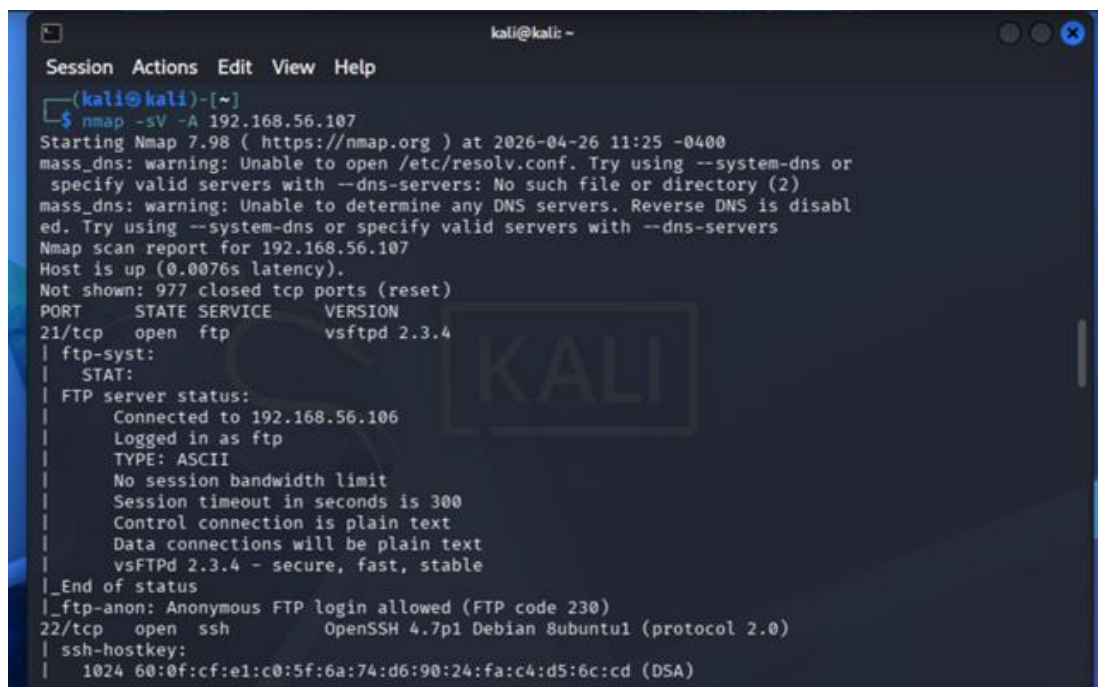
5.8.5 Análisis general de riesgo

Las vulnerabilidades identificadas representan un alto nivel de riesgo para el sistema, ya que pueden ser explotadas de manera combinada para comprometer completamente la seguridad de la máquina. La presencia de múltiples servicios vulnerables, junto con la ausencia de controles de seguridad adecuados, facilita la ejecución de ataques que pueden derivar en acceso no autorizado, robo de información, modificación de datos o control total del sistema.

En este sentido, la aplicación del estándar OWASP Top Ten permitió clasificar y comprender mejor los riesgos presentes, evidenciando la importancia de implementar buenas prácticas de seguridad en el desarrollo y configuración de sistemas.

Figura 13.

Resultados del análisis de vulnerabilidades basado en el escaneo con Nmap.



```
kali@kali: ~  
Session Actions Edit View Help  
$ nmap -sV -A 192.168.56.107  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 11:25 -0400  
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or  
specify valid servers with --dns-servers: No such file or directory (2)  
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabl  
ed. Try using --system-dns or specify valid servers with --dns-servers  
Nmap scan report for 192.168.56.107  
Host is up (0.0076s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
| ftp-syst:  
|   STAT:  
| FTP server status:  
|   Connected to 192.168.56.106  
|   Logged in as ftp  
|   TYPE: ASCII  
|   No session bandwidth limit  
|   Session timeout in seconds is 300  
|   Control connection is plain text  
|   Data connections will be plain text  
|   vsFTPd 2.3.4 - secure, fast, stable  
|_End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
| ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
```

```
kali@kali: ~  
Session Actions Edit View Help  
25/tcp open smtp Postfix smtpd  
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=0  
| COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
| Not valid before: 2010-03-17T14:07:45  
| Not valid after: 2010-04-16T14:07:45  
| sslv2:  
| SSLv2 supported  
| ciphers:  
| SSL2_DES_192_EDE3_CBC_WITH_MD5  
| SSL2_RC2_128_CBC_WITH_MD5  
| SSL2_RC4_128_WITH_MD5  
| SSL2_RC4_128_EXPORT40_WITH_MD5  
| SSL2_DES_64_CBC_WITH_MD5  
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,  
| ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
|_ssl_date: 2026-04-26T15:25:48+00:00; 0s from scanner time.  
53/tcp open domain ISC BIND 9.4.2  
| dns-nsid:  
|_bind.version: 9.4.2  
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2  
|_http_title: Metasploitable2 - Linux  
111/tcp open rpcbind 2 (RPC #100000)  
| rpcinfo:  
| program version port/proto service  
| 100000 2 111/tcp rpcbind  
| 100000 2 111/udp rpcbind
```

```
kali@kali: ~  
Session Actions Edit View Help  
| 100000 2 111/udp rpcbind  
| 100003 2,3,4 2049/tcp nfs  
| 100003 2,3,4 2049/udp nfs  
| 100005 1,2,3 44018/udp mountd  
| 100005 1,2,3 44571/tcp mountd  
| 100021 1,3,4 56530/tcp nlockmgr  
| 100021 1,3,4 56799/udp nlockmgr  
| 100024 1 39784/udp status  
| 100024 1 58641/tcp status  
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp open exec netkit-rsh rexecd  
513/tcp open login  
514/tcp open shell Netkit rshd  
1099/tcp open java-rmi GNU Classpath grmiregistry  
1524/tcp open bindshell Metasploitable root shell  
2049/tcp open nfs 2-4 (RPC #100003)  
2121/tcp open ftp ProFTPD 1.3.1  
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5  
| mysql-info:  
| Protocol: 10  
| Version: 5.0.51a-3ubuntu5  
| Thread ID: 8  
| Capabilities flags: 43564  
| Some Capabilities: SwitchToSSLAfterHandshake, ConnectWithDatabase, LongCo  
| lumnFlag, SupportsTransactions, Support41Auth, Speaks41ProtocolNew, SupportsC  
| ompression  
| Status: Autocommit
```

```
kali@kali: ~  
Session Actions Edit View Help  
|_ Salt: %C_5,{KCOA98N^m-5`gb  
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7  
|_ssl-date: 2026-04-26T15:25:48+00:00; 0s from scanner time.  
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O  
CO5A/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_Not valid before: 2010-03-17T14:07:45  
|_Not valid after: 2010-04-16T14:07:45  
5900/tcp open  vnc          VNC (protocol 3.3)  
|_vnc-info:  
|_ Protocol version: 3.3  
|_ Security types:  
|_ VNC Authentication (2)  
6000/tcp open  X11          (access denied)  
6667/tcp open  irc          UnrealIRCd  
8009/tcp open  ajp13        Apache Jserv (Protocol v1.3)  
|_ajp-methods: Failed to get a valid response for the OPTION request  
8180/tcp open  http         Apache Tomcat/Coyote JSP engine 1.1  
|_http-server-header: Apache-Coyote/1.1  
|_http-favicon: Apache Tomcat  
|_http-title: Apache Tomcat/5.5  
MAC Address: 08:00:27:9A:63:2F (Oracle VirtualBox virtual NIC)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs  
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
kali@kali: ~  
Session Actions Edit View Help  
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Host script results:  
|_ smb-os-discovery:  
|_ OS: Unix (Samba 3.0.20-Debian)  
|_ Computer name: metasploitable  
|_ NetBIOS computer name:  
|_ Domain name: localdomain  
|_ FQDN: metasploitable.localdomain  
|_ System time: 2026-04-26T11:25:40-04:00  
|_ smb-security-mode:  
|_ account_used: guest  
|_ authentication_level: user  
|_ challenge_response: supported  
|_ message_signing: disabled (dangerous, but default)  
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s  
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:  
<unknown> (unknown)  
|_ smb2-time: Protocol negotiation failed (SMB2)  
  
TRACEROUTE  
HOP RTT ADDRESS  
1 7.62 ms 192.168.56.107  
  
OS and Service detection performed. Please report any incorrect results at ht  
tps://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 23.90 seconds
```

Nota.

Se identifican múltiples vulnerabilidades críticas alineadas con el estándar OWASP Top Ten, evidenciando fallas en el control de acceso, seguridad criptográfica, configuración del sistema y validación de solicitudes en aplicaciones web.

6.Conclusiones

El desarrollo de la presente actividad permitió aplicar de manera práctica los conocimientos adquiridos en la unidad 3 relacionados con la auditoría de seguridad y el análisis de vulnerabilidades en sistemas informáticos. A través de la implementación de un entorno virtualizado, se logró simular un escenario real de pruebas de penetración, utilizando herramientas especializadas dentro de un ambiente controlado.

En primer lugar, la configuración del entorno de laboratorio mediante el uso de máquinas virtuales facilitó la creación de un espacio seguro para la ejecución de pruebas sin comprometer sistemas reales. La correcta configuración de red y la verificación de conectividad mediante herramientas como ping permitieron establecer la comunicación entre las máquinas, lo cual fue fundamental para el desarrollo de las pruebas posteriores.

Asimismo, el uso de la herramienta Nmap permitió identificar múltiples servicios activos en la máquina víctima, evidenciando una amplia superficie de ataque. Este proceso de reconocimiento resultó clave para detectar posibles vulnerabilidades asociadas a servicios desactualizados, configuraciones inseguras y exposición innecesaria de puertos. Por otra parte, la ejecución de pruebas sobre aplicaciones web, específicamente el ataque de tipo Cross-Site Request Forgery (CSRF), permitió evidenciar la falta de mecanismos de validación en la aplicación DVWA, demostrando cómo un atacante puede realizar acciones no autorizadas en nombre de un usuario legítimo.

De igual manera, la validación de la seguridad en la capa de transporte evidenció la ausencia de protocolos seguros como HTTPS, así como la utilización de mecanismos criptográficos obsoletos, lo cual representa un riesgo significativo para la confidencialidad de la información. Finalmente, el análisis de vulnerabilidades basado en el estándar OWASP Top Ten permitió clasificar y comprender los riesgos identificados durante la actividad, destacando fallas en el

control de acceso, errores criptográficos, configuraciones inseguras y vulnerabilidades en aplicaciones web.

En conclusión, esta actividad permitió integrar conceptos teóricos con su aplicación práctica, fortaleciendo las competencias en análisis de seguridad y auditoría de sistemas. Asimismo, resalta la importancia de implementar buenas prácticas de seguridad en el desarrollo y configuración de sistemas informáticos, con el fin de prevenir posibles ataques y proteger la información.

7.Referencias

Barchino Plata, R., Sánchez Rubio, M., & Martínez Herráiz, J. (2020). Redes de computadores. Editorial RA-MA.

Lyon, G. F. (2009). Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Insecure.

Menejías García, R., Hidalgo Reyes, N. H., Marín Díaz, A., & Trujillo Casañola, Y. (2021). Procedimiento para evaluar seguridad a productos de software. Revista Cubana de Ciencias Informáticas, 15(4), 333–347.

OWASP Foundation. (2023). OWASP Top Ten Web Application Security Risks.
<https://owasp.org/www-project-top-ten/>